



Administrator and Production Support Manual

TASCO Insurance × VETC Growth Platform — User Manuals

iorta TechNXT

Version 1.0 · 07 October 2026

Contents

- Part A — User administration (administrator)
- Part B — Operations (administrator and support engineer)
- Troubleshooting (quick reference)

Platform administrator		Support engineer
Role	admin	support_engineer
Demo user	admin (MFA required)	support
Permissions	users:manage , ops:read , ops:run_jobs , audit:read , rules:read , dashboard:read	ops:read , ops:run_jobs
Landing page	Home	Operations

Separation of duties: administrators manage accounts and operations but **cannot author or approve rules and cannot see customer personal data**. Support engineers can see operational status and run jobs only. They cannot see customers, dashboards or rules. Do not request extra roles to "make support easier". Escalate instead.

Read the [Staff User Manual](#) first. Technical runbooks (RB-01 ... RB-15) and standard operating procedures (SOP-01 ... SOP-09) are in [docs/operations/runbook-and-support-guide.pdf](#) . This manual covers day-to-day use of the Users and Operations pages.

Part A — User administration (administrator)

A1. Roles reference

Role	Give to	MFA	Key capabilities
admin	Platform administrators (2–3 people)	Required	Users, operations, audit read
executive	Leadership	Recommended	Dashboards
campaign_manager	Marketing / growth		Leads, journeys, voice campaigns, rules read
telesales_agent	Agents (set region)		Handoffs, customers with PII, quote and issue
telesales_supervisor	Team leads		Agent rights + assign handoffs + dashboards
rule_author	Product analysts		Draft and simulate rules
rule_approver	Compliance, underwriting approvers	Required	Approve or reject rules, audit read
compliance_officer	Compliance / DPO office	Required	Approve rules, audit, DSAR
data_steward	Data team	Required	DQ, corrections, ingestion, PII
claims_handler	Claims team		FNOL queue
partner_manager	Partnerships		Partners, API keys, statements
auditor	Internal audit	Recommended	Read-only audit, rules, dashboards
support_engineer	Production support		Operations status and jobs

Roles requiring MFA are set by configuration (`MFA_REQUIRED_ROLES` , default `admin,rule_approver,compliance_officer,data_steward`). A user with such a role **cannot sign in** until MFA is enrolled ("MFA enrolment required for your role — contact an administrator").

Least privilege: choose only the roles the person needs. Never combine `rule_author` with `rule_approver` for the same person. The platform still blocks self-approval, but the separation should be organisational too.

A2. Create a user

Prerequisites: approved access request (manager + data owner for PII roles), training certification for the role (see the change and training plan), and the user's region.

1. Open **Users** and select **Create user**.
2. Enter:
 - **Username:** lowercase letters, digits, `.`, `_`, `-` (for example `nguyen.van.an`);
 - **Display name;**
 - **Temporary password:** at least 12 characters (maximum 128);
 - **Roles:** tick the required roles ("Least privilege — choose only what the person needs");
 - **Region:** for agents and supervisors the exact region name used in customer data (for example `Hà Nội`, `TP. Hồ Chí Minh`), otherwise `ALL`;
 - **Enrol MFA (mandatory for privileged roles):** tick for any role in the MFA list (recommended for everyone).
3. Select **Create**.

What you will see: "Created `<username>` ." If MFA was enrolled: "**Authenticator secret (show once):** `<secret>` ".

4. Give the user the temporary password and the authenticator secret through **separate secure channels** (for example the password in person, the secret through the secure service-desk channel). The user adds the secret to their authenticator app as a time-based (TOTP) account, 6 digits, 30 seconds.
5. Ask the user to sign in and change the password at once (user menu → Change password).

The action is audited (`user.created` , with roles and region).

Production with corporate single sign-on (OIDC to TASCO's IdP): accounts and MFA are managed in the IdP, and this page is used only for role and region mapping. This is planned for scale-out.

A3. Change roles, region or status

1. Open **Users** and find the user (search by username).
2. Change **Roles** and/or **Region**, or select **Disable** / **Enable**.
3. Save.

What you will see: the updated row. Disabling takes effect at once: the user's existing session stops working on the next request. Audited as `user.updated` .

You **cannot remove your own admin role** ("You cannot remove your own admin role"). Another administrator must do it.

A4. Leavers and movers

- **Leaver:** **Disable** on or before the last day. Do not delete accounts, because the audit trail needs them.

- **Mover:** change roles and region on the effective date. Remove roles that are no longer needed.
- **Quarterly access review:** export the user list (roles, region, last login, status) for Security and Compliance. Disable accounts with no login for 90 days unless justified.

A5. Locked accounts, forgotten passwords and lost MFA devices

v1 has **no administrator API** to unlock an account, reset a password or re-enrol MFA (known issue **KI-27** in [docs/quality/test-strategy.pdf](#)). Until it is fixed, follow **SOP-08** in [docs/operations/runbook-and-support-guide.pdf](#) :

Situation	v1 procedure
Locked after 5 failed attempts	The lock clears automatically after 15 minutes (<code>LOCKOUT_MINUTES</code>). Verify the user's identity before advising them. Repeated lockouts may indicate an attack: check <code>auth.login_failed</code> in Audit . For urgent cases, L3 unlocks under SOP-08 (change ticket, break-glass).
Forgotten password	Disable the account at once if compromise is suspected. Then either L3 resets it under SOP-08, or you create a replacement account (for example <code>nguyen.van.an2</code>) with the same roles and record the link in the ticket. Under IdP federation this is handled in the IdP.
Lost or new phone (MFA)	Disable the account at once to protect it. Then either L3 re-enrols MFA under SOP-08, or you create a replacement account with Enrol MFA .

A6. Sandbox-only demo accounts

Demo users (`admin` , `exec` , `campaign` , `agent.hn` , `agent.hcm` , `supervisor` , `author` , `approver` , `compliance` , `steward` , `claims` , `partners` , `auditor` , `support`) with password `Tasco@Demo2026!` exist **only** when the platform is seeded in demo mode. Production must **never** run with `DEMO_MODE` (the server refuses to start in production with demo mode unless explicitly overridden). The demo MFA helper `GET /api/demo/totp/:username` returns 404 when demo mode is off.

Part B — Operations (administrator and support engineer)

B1. Operations page

Open **Operations**. What you will see:

Section	Meaning	Healthy state
Store	<code>postgres</code> (production) or <code>memory</code> (demo/dev)	<code>postgres</code> in production
Integrations: name and circuit	Circuit breaker state for each external system: <code>vetc-wallet</code> , <code>tasco-core</code> , <code>voice-ai</code> , <code>app-push</code> , <code>zalo-zns</code> , <code>sms</code>	closed (normal). open means calls are failing fast; half_open means it is testing recovery.
Active rules	Each rule kind with active version and checksum	All expected kinds present. Checksums match the change log.
Event backlog	Domain events by status (outbox)	Pending count near zero and not growing
Audit entries	Total audit records	Growing steadily
Job history	Recent job runs: kind, actor, started, finished, status (<code>succeeded</code> / <code>failed</code>), result	Scheduled jobs succeeded

B2. Run a job manually

1. In **Operations**, choose the job:

Job	What it does	When to run manually
Reconciliation	Checks every order: completed orders must have a payment reference and every policy must exist; orders stuck in <code>pending_payment</code> for more than 1 hour are flagged	After a payment or issuance incident, or when Finance queries
Retention	Applies the <code>retention</code> rule set (deletes raw source records after 365 days and voice sessions after 180 days; other entities are flagged for the archival pipeline)	Only if the scheduled run failed
Relay	Processes pending domain events (outbox)	When the event backlog grows

2. Select **Run** and confirm.

3. **What you will see:** the result. For reconciliation, the number checked, the number of mismatches and up to 100 details (order ID and issue). The run appears in **Job history** and is audited (`job.<kind>`).

Equivalent command-line jobs (scheduled in production): `npm run job -- journeys | recompute | reconcile | retention | relay | rules | migrate | seed | openapi`.

B3. Health and monitoring endpoints

Endpoint	Use
GET <code>/health/live</code>	Liveness: the process is up (<code>{"status":"ok"}</code>)
GET <code>/health/ready</code>	Readiness: the database is reachable (<code>200 ready / 503 not_ready</code> , with <code>db: true/false</code>). Load balancers use this.
GET <code>/metrics</code>	Prometheus metrics: <code>http_requests_total</code> , <code>http_request_duration_seconds</code> , <code>voice_calls_total</code> , <code>quotes_total</code> , <code>orders_completed_total</code> , <code>messages_total</code>
GET <code>/api/meta</code>	Version, demo mode flag, current date, store type
GET <code>/api/ops/status</code>	Operations page data (needs <code>ops: read</code>)
GET <code>/api/audit/verify</code>	Audit chain integrity (needs <code>audit: read</code> : admin only, not support)

Logs are structured JSON. Every request has a **request ID** (`X-Request-Id` header and `requestId` field). Users see it as the "support code" on errors. Search logs by it.

B4. Incident triage guide

Symptom	Check	Action
Users cannot sign in (everyone)	<code>/health/ready</code> , database, <code>JWT_SECRET</code> unchanged	Restore the database connection. If the secret was rotated, all sessions end, which is expected.
Customers' payments fail	Operations → <code>vetc-wallet</code> circuit open . Order statuses <code>payment_failed</code> .	Contact VETC wallet on-call. Run reconciliation after recovery.

Symptom	Check	Action
Orders paid but no certificate	<code>tasco-core</code> circuit. Orders <code>issuance_failed_refunded</code> .	Refunds happen automatically. Confirm with Finance. Contact TASCO core. Run reconciliation.
Reminders not sent	<code>zalo-zns</code> , <code>sms</code> , <code>app-push</code> circuits. Journey run summary. Messages failed.	Contact the provider. Re-run journeys after recovery (campaign manager).
Voice calls failing	<code>voice-ai</code> circuit	Contact the vendor. Campaigns pause by themselves.
Event backlog growing	Operations → event backlog	Run Relay . If it persists, check logs for subscriber errors.
Audit chain verification broken	Audit → Verify	Security incident : do not modify data. Escalate to Security and Compliance. Preserve logs.
Rule change "not taking effect"	Active rules checksum	Wait 15 s (cache). Check that it was approved, not just submitted. Ask for lead recompute.
"Too many requests" for many users	Rate limits (<code>RATE_LIMIT_MAX</code> , default 300/min per IP; sign-in 10/min)	Behind a proxy, check <code>TRUST_PROXY</code> . Otherwise many users may share one IP. Raise the limit by configuration change (CAB).

Severity and response (proposed): P1 (sales or sign-in down for all) respond 15 min, restore 4 h. P2 (one channel or integration down) 30 min / 8 h. P3 (single user or function) 4 h / 3 business days.

B5. Configuration and secrets (reference)

Set through environment variables. Secrets can be supplied as files with `<NAME>_FILE`.

Setting	Purpose
<code>NODE_ENV=production</code>	Enables strict checks (secrets required, demo mode refused)
<code>DATABASE_URL</code> , <code>DATABASE_SSL</code> , <code>DB_POOL_MAX</code>	PostgreSQL
<code>JWT_SECRET</code> , <code>JWT_TTL_SECONDS</code> (default 1800)	Staff and customer tokens
<code>DATA_KEYS</code> , <code>DATA_KEY_ACTIVE</code>	Field encryption keys (<code>id:base64-32-bytes</code> , comma-separated) for rotation
<code>BLIND_INDEX_KEY</code>	Searchable encrypted fields
<code>MFA_REQUIRED_ROLES</code>	Roles that must use MFA
<code>LOCKOUT_MAX_FAILURES</code> (5), <code>LOCKOUT_MINUTES</code> (15)	Account lockout
<code>RATE_LIMIT_WINDOW_MS</code> , <code>RATE_LIMIT_MAX</code> , <code>RATE_LIMIT_LOGIN_MAX</code>	Rate limiting
<code>CORS_ORIGINS</code> , <code>TRUST_PROXY</code> , <code>PUBLIC_BASE_URL</code>	Web and network
<code>DEMO_MODE</code> , <code>SEED_RECORDS</code> , <code>SEED</code> , <code>SIM_TODAY</code>	Sandbox only

Changes to RBAC (`config/security/rbac.json`) and security settings go through code review and the **Change Advisory Board**. They are never edited on a running server.

Troubleshooting (quick reference)

Message	Meaning	Fix
"Unknown role X"	Typo in the role name	Use a role from the A1 table
"Password policy: at least 12 characters"	Temporary password too short	Use 12–128 characters
"Username already exists"	Duplicate	Choose another username
"Job kind not found"	Wrong job name	Use reconciliation, retention or relay
"Missing permission ops:run_jobs"	Read-only operations role	Ask an administrator or support engineer

See also: [docs/operations/runbook-and-support-guide.pdf](#) (runbooks), [docs/delivery/kt-plan.pdf](#) (KT), [Staff User Manual](#).